

Security+ 2.4 · Malicious Code

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 2.4** —

Malicious Code (3:40) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Attacker code: custom scripts (Python/Bash/PowerShell) for known exploits; Office VBA macros that download malware; shellcode. Defenses: patching, macro security (block external macros), sandboxing, behavioral EDR, code review of user scripts.

High-Yield Core Concepts Tested on Exam

- Office document VBA macro: classic — executes code when opened
- Sandbox: isolates suspicious code in a controlled environment
- Custom scripts (Python/Bash/PowerShell) exploit known vulnerabilities
- Behavioral EDR detects malicious code execution patterns
- Macro security blocks external macros by default

Exam Tips & Classic Scenarios

- 'document that runs code when opened' = malicious macro
- Sandboxing is a key defense against malicious code execution

Typical Exam Scenario: Scenario: 'employee opens a spreadsheet from email and the macro executes a payload' = malicious macro — block external macros.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 2.4 — Malicious Code)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **WORM:** Write Once, Read Many: Immutable optical/cloud storage paradigm preventing data alteration or deletion during retention periods (critical for audit logs).

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. Which type of malware spreads automatically across networks without the need for a host file or user interaction?

- A) Worm
- B) Trojan
- C) Spyware
- D) Adware

2. Malware that encrypts your files and demands payment to return them is:

- A) Spyware
- B) Ransomware
- C) Rootkit
- D) Worm

3. Corporate scenario (Malicious Code): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'VBA macro in Office document: classic — executes code upon opening'. What is the best applicable recommendation or control classification?

- A)** Implement the corresponding solution: VBA macro in Office document: classic — executes code upon opening...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

4. Corporate scenario (Malicious Code): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Sandbox: isolates suspicious code in a controlled environment'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Sandbox: isolates suspicious code in a controlled environment...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

5. Corporate scenario (Malicious Code): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'document that runs code when opened' = malicious macro'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: 'document that runs code when opened' = malicious macro...

6. Corporate scenario (Malicious Code): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Scenario: 'employee opens spreadsheet from email and macro executes payload' = malicious macro — block external macros.'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Scenario: 'employee opens spreadsheet from email and macro executes payload' = malicious macro...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

7. Corporate scenario (Malicious Code): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'VBA macro in an Office document: classic — executes code upon opening'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to speed up system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: VBA macro in an Office document: classic — executes code upon opening...

8. Corporate scenario (Malicious Code): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Sandbox: isolates suspicious code in a controlled environment'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: Sandbox: isolates suspicious code in a controlled environment.

9. Corporate scenario (Malicious Code): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'document that runs code when opened' = malicious macro. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'document that runs code when opened' = malicious macro...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

10. Corporate scenario (Malicious Code): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Scenario: 'employee opens spreadsheet from email and macro executes payload' = malicious macro — block external macros.'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Scenario: 'employee opens spreadsheet from email and macro executes payload' = m...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) A — Worm.

✓ **Why it's correct:** A Worm is a type of standalone malware that self-replicates and spreads automatically across networks, exploiting vulnerabilities in services or operating systems, without the need for a host file or user interaction. Unlike viruses, it does not need a carrier program to propagate. In CompTIA Security+ (domain 2.4 - 'Given a scenario, analyze indicators of malicious activity'), a worm is classically defined as malware that spreads on its own across the network, consuming bandwidth and compromising systems at scale. This is exactly what the question describes.

✗ **Why the others are wrong:**

- *Trojan*: A Trojan is malware that disguises itself as legitimate software to trick the user into executing it. It depends on user interaction to infect the system and does not self-replicate automatically across the network. Therefore, it does not meet the criterion of 'spreading automatically without user interaction'.
- *Spyware*: Spyware is malicious software designed to collect user information without consent, such as browsing habits, credentials, and personal data. It does not spread automatically across networks; it is typically installed through social engineering or bundled with other software. Thus, it is not the correct answer.
- *Adware*: Adware is software that displays unwanted advertisements and may redirect the browser, but it does not self-replicate or spread automatically across networks. Its dissemination depends on user installation or other malware. Therefore, it does not meet the question's criteria.

2) B — Ransomware.

✓ **Why it is correct:** The correct answer is 'Ransomware'. Ransomware is a type of malware that encrypts the victim's files and demands a ransom payment (usually in cryptocurrency) to provide the decryption key. The statement describes exactly this behavior: malware that encrypts files and demands payment to return them. CompTIA classifies ransomware as a critical threat, often propagated through phishing, vulnerability exploitation, or remote desktop services. Therefore, the option 'Ransomware' is the precise definition of the described attack.

✗ **Why the other options are wrong:**

- *Spyware*: Spyware is malicious software designed to collect information from the infected system without the user's consent, such as browsing habits, credentials, banking data, etc. It does not encrypt files or demand ransom. Its primary function is to spy and exfiltrate data. In the scenario, the goal is to extort money through file encryption, which is not a characteristic of spyware. Therefore, spyware does not apply.
- *Rootkit*: A rootkit is a set of malicious tools that allows an attacker to gain privileged access (root) and maintain persistence on the system, hiding its presence from detection mechanisms. Although it can be used in conjunction with ransomware, a rootkit itself does not encrypt files or demand payment. Its purpose is stealth, not extortion. The statement describes a financial extortion attack via encryption, not the installation of a rootkit. Thus, rootkit is not the correct answer.
- *Worm*: A worm is self-replicating malware that spreads automatically across the network, exploiting vulnerabilities, without necessarily needing a host file or user interaction. Although worms can carry payloads like ransomware, they are not defined by encrypting files and demanding ransom. The behavior described in the statement is specific to ransomware, not a worm. Therefore, worm is an incorrect classification for the attack in question.

3) A — Implement the corresponding solution: VBA macro in Office document: classic — executes code upon opening....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Malicious Code): VBA macro in Office document: classic — executes code upon opening. This is a common attack vector where malicious macros run automatically when a document is opened, often used to deliver malware.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

4) B — Implement the corresponding solution: Sandbox: isolates suspicious code in a controlled environment....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Malicious Code): Sandbox: isolates suspicious code in a controlled environment. A sandbox is an isolated environment used to safely execute and analyze potentially malicious code without risking the production system, allowing security analysts to observe behavior and determine if the code is malicious.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

5) D — Implement the corresponding solution: 'document that runs code when opened' = malicious macro....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Malicious Code): 'document that runs code when opened' = malicious macro. A malicious macro is embedded in documents (e.g., Office files) and executes code when the document is opened, often used for initial access or payload delivery. Mitigations include disabling macros, user awareness, and application control.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks,

injections, or malware at runtime.

- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

6) A — Implement the corresponding solution: Scenario: 'employee opens spreadsheet from email and macro executes payload' = malicious macro....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Malicious Code): Scenario: 'employee opens spreadsheet from email and macro executes payload' = malicious macro — block external macros. Malicious macros are a common attack vector, and blocking macros from external sources is a key preventive control.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who made critical changes or executed malicious commands.

7) D — Implement the corresponding solution: VBA macro in an Office document: classic — executes code upon opening....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Malicious Code): VBA macro in an Office document: classic — executes code upon opening.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to speed up system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

8) D — Implement the corresponding solution: Sandbox: isolates suspicious code in a controlled environment..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Malicious Code): Sandbox: isolates suspicious code in a controlled environment. Sandboxing detonates and analyzes potentially malicious code in an isolated environment to prevent harm to the production system. It is a key defense against advanced malware and zero-days.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks

compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

9) A — Implement the corresponding solution: 'document that runs code when opened' = malicious macro....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Malicious Code): 'document that runs code when opened' = malicious macro.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) A — Implement the corresponding solution: Scenario: 'employee opens spreadsheet from email and macro executes payload' = m....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Malicious Code): Scenario: 'employee opens spreadsheet from email and macro executes payload' = malicious macro — block external macros. Blocking external macros prevents malicious code execution from documents received via email.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.